Universidad de las Fuerzas Armadas ESPE

Ingeniería en Software



Proyecto Integrador del Primer Parcial

Autenticación JWT, autorización RBAC y detección de esteganografía

Informe técnico del Backend V1

Estudiantes	Andrade Danna, Tufiño Erick y Pilaguano David
Asignatura	Desarrollo de Software Seguro
NRC	36902
Unidad	1
Fecha	5 de noviembre de 2026

Índice

1. Resumen **3**

2. Introducción y objetivos **3**
2.1. Objetivo general . . . 3
2.2. Objetivos específicos . . . 3
2.3. Alcance . . . 3

3. Metodología y organización del desarrollo **3**

4. Requisitos y trazabilidad **4**

5. Arquitectura e implementación **5**
5.1. Despliegue y configuración . . . 6
5.2. Flujo de una solicitud . . . 6

6. Modelo de datos y persistencia **7**

7. Contratos REST y seguridad **7**
7.1. Autenticación, sesión y autorización . . . 8
7.2. Errores y auditoría . . . 8
7.3. Contratos OpenAPI entregados . . . 9

8. Análisis de esteganografía **9**
8.1. Extracción de indicadores LSB . . . 9
8.2. Criterios de clasificación y política . . . 10

9. Diseño de pruebas y resultados **12**
9.1. Controles previos al commit y Postman . . . 13
9.2. Diseño y uso de la colección de Postman . . . 13

10. Riesgos y prácticas seguras **14**

11. Limitaciones y conclusiones **15**
11.1. Limitaciones . . . 15
11.2. Conclusiones . . . 15

12. Instalación, ejecución y sustentación **15**

13. Referencias **16**

A. Matriz completa de activos, amenazas y controles **16**

B. Matriz de enfoque y principios **20**

C. Matriz de evidencia reproducible **20**

D. Evidencias de ejecución **22**

D.1. Backend en ejecución en Swagger 25

D.2. Creación y consulta de un análisis 27

E. Repositorio y artefactos técnicos **28**

1. Resumen

El Backend V1 de la aplicación de chat separa la gestión de identidades del análisis de imágenes. AUTH administra usuarios y roles en PostgreSQL, protege las contraseñas con Argon2id y firma tokens JWT mediante RS256. STEGO valida archivos PNG, analiza sus bits menos significativos (LSB) y guarda los resultados en SQLite. Antes de analizar una imagen, STEGO verifica el token y consulta a AUTH por TLS para confirmar que el usuario conserva el permiso requerido. La validación local aprobó 53 pruebas automáticas, los 12 escenarios oficiales de integración y las 37 solicitudes de la colección Postman ejecutadas con Newman. La clasificación del detector expresa el grado de sospecha según una heurística. **Palabras clave:** microservicios, JWT, RBAC, LSB, seguridad, Zero Trust.

2. Introducción y objetivos

La primera entrega prepara identidad y análisis de contenido antes de implementar salas, mensajería o interfaz. Autenticación identifica al sujeto; autorización determina si mantiene permiso. Un JWT válido no sustituye la consulta de roles actuales. Los archivos se consideran entradas no confiables. El informe toma ISO/IEC 27001 e ISO/IEC 27034 como referencias académicas.

2.1. Objetivo general

Diseñar, integrar y evaluar dos servicios independientes que permitan analizar imágenes PNG con permisos vigentes y conservar evidencia de cada análisis.

2.2. Objetivos específicos

- Modelar la relación de muchos a muchos (N:M) entre usuarios y roles.
- Proteger las credenciales, verificar los JWT y aplicar permisos revocables mediante control de acceso basado en roles (RBAC).
- Validar archivos PNG, analizar sus LSB y evaluar los límites de la clasificación con muestras de referencia.
- Vincular los requisitos y controles de seguridad con pruebas reproducibles.

2.3. Alcance

El alcance excluye interfaz, salas, mensajería en tiempo real, cifrado extremo a extremo y restricción de dispositivos.

3. Metodología y organización del desarrollo

La metodología de validación comprende pruebas del dominio, de los contratos REST y de la comunicación entre servicios. Los criterios de aceptación incluyen el código HTTP,

el contenido de la respuesta y, cuando corresponde, el estado persistido o el evento de auditoría.

Cuadro 1: Organización del trabajo por componentes

Componente	Actividades	Productos verificables
Identidad y acceso	Modelado N:M, migraciones, gestión de usuarios, firma JWT y autorización vigente	AUTH, esquema PostgreSQL y contrato de identidad
Análisis de contenido	Validación de carga, cálculo de métricas LSB, clasificación y persistencia	STEGO, corpus de prueba y registro SQLite
Integración y despliegue	Comunicación TLS, credencial entre servicios, volúmenes y configuración local	Docker Compose, arranque reproducible y recuperación del servicio
Validación y documentación	Pruebas unitarias, de extremo a extremo, de integración y de contrato REST	Matrices, colección Postman, evidencias y guía de reproducción

Danna Andrade se encargó de la documentación técnica y la organización de las evidencias. Erick Tufiño y David Pilaguano trabajaron conjuntamente en la implementación del código, el diseño de la arquitectura y la ejecución de las pruebas.

La implementación se comprobó en tres niveles. Las pruebas unitarias aislaron la lógica del dominio. Las pruebas de extremo a extremo recorrieron rutas y validaciones de cada aplicación. Las pruebas de integración ejecutaron ambos servicios en Docker para comprobar los efectos que dependen de su comunicación, como la revocación de un rol y la caída de AUTH. La colección REST constituyó una comprobación adicional desde el punto de vista del cliente.

4. Requisitos y trazabilidad

La matriz vincula los requisitos del Backend V1 con sus componentes y con las pruebas que permiten comprobarlos. El detalle operativo se encuentra en `Codigo/PLAN_PRUEBAS_PRE_COMMIT.md`.

Cuadro 2: Trazabilidad de requisitos

Requisito	Implementación	Evidencia
Separación	AUTH/STEGO en contenedores independientes	T01, Compose
Modelo N:M	users, roles, user_roles, FK y unicidad	T05–T06
JWT	Argon2id, RS256 y claims estrictos	T02–T03
RBAC vigente	AUTH decide por operación, fail-closed	T04, T07–T08
Análisis	PNG, LSB, SHA-256 y límites	T09–T10
Documentación	OpenAPI, riesgos, evidencias, Postman	T12

5. Arquitectura e implementación

El sistema se compone de dos aplicaciones NestJS en TypeScript ejecutadas en Node.js. Docker Compose levanta tres contenedores independientes. AUTH usa TypeORM y PostgreSQL para identidad. STEGO utiliza Sharp para decodificar PNG y SQLite para conservar los resultados. Cada aplicación mantiene su propio proceso, configuración, contrato REST y almacenamiento.

La separación es operativa y de responsabilidades: AUTH conserva usuarios, roles, credenciales y la clave privada RSA; STEGO valida las imágenes y mantiene los análisis, y sólo recibe la clave pública JWT y la CA necesaria para verificar el canal interno. PostgreSQL es infraestructura de AUTH, no un tercer microservicio de negocio. La independencia de despliegue no elimina la dependencia funcional de autorización: si AUTH no responde, STEGO deniega la operación.

Las tecnologías se distribuyen según el límite de confianza: NestJS y TypeScript implementan las APIs; TypeORM y PostgreSQL persisten la identidad; Argon2id protege las contraseñas; JWT RS256 permite validación asimétrica; Sharp decodifica imágenes; SQLite registra análisis; Docker Compose organiza contenedores, red y volúmenes; Swagger/OpenAPI documenta los contratos.

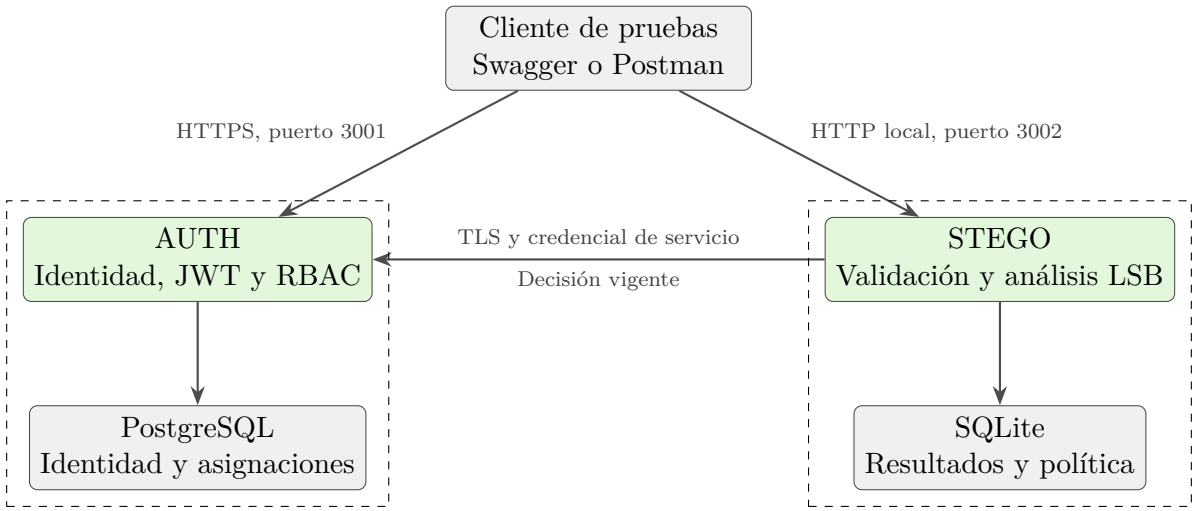


Figura 1: Componentes, almacenamiento y límites de confianza. Los recuadros punteados delimitan la responsabilidad de cada servicio.

5.1. Despliegue y configuración

Compose publica los puertos en la interfaz local. El puerto 5435 sirve conexiones PostgreSQL y el 5432 es su puerto interno. AUTH y STEGO redirigen la raíz a Swagger. AUTH usa una CA de desarrollo para HTTPS y STEGO confía en ella para las consultas internas. Los secretos se generan al preparar el entorno. La clave privada JWT permanece en AUTH y STEGO recibe la pública. Ambos servicios leen su credencial compartida de `secrets/service.env`, un archivo local excluido de Git. Se generan 32 bytes aleatorios al preparar la instalación y se conserva el valor al reiniciar.

5.2. Flujo de una solicitud

1. El cliente inicia sesión en AUTH y obtiene un JWT de acceso firmado.
2. El cliente presenta el JWT a STEGO. STEGO valida sus datos criptográficos antes de aceptar la operación.
3. STEGO consulta a AUTH por TLS. Para leer un análisis, incluye el UUID solicitado y su propietario, obtenido de SQLite.
4. AUTH verifica el estado de la cuenta y los roles vigentes. Para una lectura también aplica la regla de propiedad y devuelve una decisión vinculada al UUID.
5. STEGO comprueba la correspondencia de la decisión con el sujeto, la acción y el recurso. Si la acción fue autorizada, procesa el PNG o devuelve el resultado tras comprobar nuevamente la propiedad. Si AUTH resulta inaccesible, STEGO devuelve 503.

6. Modelo de datos y persistencia

PostgreSQL conserva usuarios, roles y sus asignaciones. `user_roles` enlaza a las dos tablas mediante claves foráneas. La restricción `UNIQUE(user_id, role_id)` impide duplicar una asignación. Los registros activos y el borrado lógico determinan qué roles se consideran vigentes.

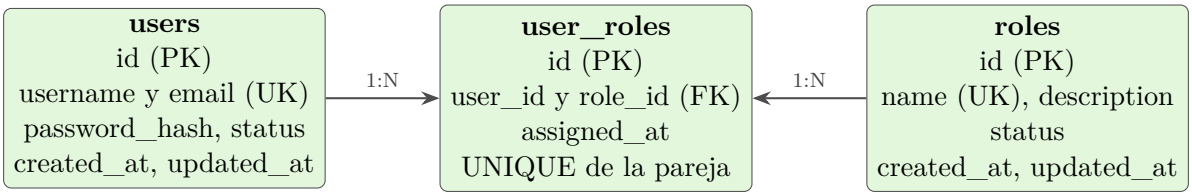


Figura 2: Modelo relacional de identidad y asignaciones N:M.

La migración `1793851200000-AlignIdentitySchema.ts` renombró columnas del esquema inicial y conservó los valores existentes, claves y restricciones. TypeORM ejecuta las migraciones al arrancar AUTH con sincronización automática desactivada. SQLite almacena el identificador del análisis, propietario, nombre del archivo, SHA-256, técnica, indicadores, estado, política, limitaciones y fecha. El archivo original se procesa en memoria. Los volúmenes persisten de forma independiente. La prueba de entrega recuperó el mismo UUID, SHA-256 y clasificación tras recrear el contenedor STEGO.

7. Contratos REST y seguridad

Cada servicio publica OpenAPI en `/docs-json` y Swagger en `/docs`. Las rutas administrativas requieren un JWT válido y el rol ADMIN vigente.

Cuadro 3: Operaciones obligatorias y reglas de acceso

Servicio	Método	Ruta	Acceso
AUTH	POST	`/api/auth/login`	Credenciales válidas
AUTH	GET / POST	`/api/auth/profile`, `/api/auth/logout`	Sesión autenticada
AUTH	POST, GET	`/api/users`, `/api/roles`	ADMIN
AUTH	PATCH	`/api/users/:id`, `/api/roles/:id`	ADMIN
AUTH	POST, DELETE	`/api/user-roles`, `/api/user-roles/:id`	ADMIN
AUTH	POST	`/internal/authorization/check`	Identidad de servicio y JWT
STEGO	POST	`/api/steganography/analyze`	ANALYST o ADMIN
STEGO	GET	`/api/steganography/results/:id`	ANALYST propietario o ADMIN

7.1. Autenticación, sesión y autorización

AUTH verifica contraseñas mediante Argon2id y firma los tokens con RS256. El JWT incluye `sub`, `typ` y `tokenVersion`, además de emisor, audiencia y expiración. Los roles se consultan al decidir la operación. El cierre de sesión y el cambio de contraseña invalidan tokens anteriores mediante el versionado de sesión. Revocar un rol afecta la siguiente operación incluso si el JWT sigue vigente.

El token está formado por encabezado, payload y firma codificados en Base64URL. RS256 firma con la clave privada de AUTH y permite verificar con la clave pública distribuida a STEGO; no cifra el contenido del payload. La validación restringe explícitamente el algoritmo y comprueba firma, emisor, audiencia, expiración, tipo de token y versión de sesión. Los roles no se consideran autoridad contenida en el JWT: AUTH consulta las asignaciones activas en PostgreSQL para cada decisión. Así se distingue la autenticidad de la sesión de la autorización vigente.

Para las lecturas, AUTH usa el identificador y el propietario consultado por STEGO para distinguir un recurso propio, ajeno e inexistente. STEGO valida que el resultado de la autorización haga referencia al UUID recibido y vuelve a comprobar la propiedad al servir el registro. La autenticación entre servicios usa un secreto aleatorio y una comparación en tiempo constante para valores de igual longitud. La prueba directa rechazó con 401 la credencial fija histórica.

Cuadro 4: Permisos por rol

Operación	USER	ANALYST	ADMIN
Consultar perfil y cerrar sesión propia	Sí	Sí	Sí
Administrar usuarios, roles y asignaciones	Restringido	Restringido	Sí
Analizar imágenes PNG	Restringido	Sí	Sí
Consultar análisis propio	Restringido	Sí	Sí
Consultar análisis ajeno	Restringido	Restringido	Sí

7.2. Errores y auditoría

Los códigos 401 y 403 distinguen sesión inválida y permiso insuficiente. Un recurso inexistente devuelve 404 a un usuario con permiso de lectura. Un conflicto de unicidad devuelve 409. Para cargas se usan 413, 415 y 422. El límite de intentos devuelve 429 y la indisponibilidad de AUTH devuelve 503. Los servicios propagan el identificador de solicitud y registran eventos con campos permitidos. La evidencia de auditoría conserva actor, acción, decisión y recurso con las credenciales depuradas.

La decisión de AUTH es específica para la acción y, en las consultas, queda vinculada al identificador del análisis y a su propietario. STEGO compara la respuesta con el sujeto, acción y recurso solicitados, además de volver a validar la propiedad antes de entregar

el registro. La identidad del servicio se transmite en `x-service-token` por HTTPS y el identificador `x-request-id` permite correlacionar las bitácoras.

7.3. Contratos OpenAPI entregados

Además de Swagger generado por cada servicio en ejecución, el paquete complementario incluye contratos OpenAPI 3 en `openapi/auth.openapi.yaml` y `openapi/stego.openapi.yaml`. Estos archivos hacen reproducible la descripción de las rutas, esquemas y respuestas sin depender de que los contenedores estén activos. AUTH documenta operaciones de sesión, administración y autorización interna; STEGO documenta análisis multipart y consulta de resultados. Deben contrastarse con Swagger cuando cambie la implementación para evitar divergencias entre contrato y servicio.

8. Análisis de esteganografía

El endpoint multipart acepta un archivo de hasta 5 MiB y comprueba el permiso antes de procesarlo. Verifica extensión PNG, MIME `image/png` y firma binaria. Admite PNG RGB/RGBA de 8 bits, estáticos y sin perfil ICC. Sharp limita la carga a 16 millones de píxeles y la decodificación a cinco segundos. Solo se analizan canales RGB. Si la decodificación falla, la respuesta 422 incluye el identificador de un registro con estado `error`, consultable por el propietario autorizado o ADMIN.

8.1. Extracción de indicadores LSB

Tras decodificar la imagen, el detector concatena los canales RGB de 8 bits en una secuencia de n muestras. Para cada muestra x_i extrae el bit menos significativo:

$$b_i = x_i \,\&\, 1, \qquad b_i \in \{0, 1\}. \tag{1}$$

Sean o la cantidad de unos y $n - o$ la cantidad de ceros. La proporción de unos p y la tasa de transiciones consecutivas t se calculan así:

$$p = \frac{1}{n} \sum_{i=1}^{n} b_i = \frac{o}{n}, \tag{2}$$

$$t = \frac{1}{n-1} \sum_{i=2}^{n} \mathbb{1}(b_i \neq b_{i-1}). \tag{3}$$

El estadístico de Pearson compara el conteo observado con el balance esperado de 50 % de ceros y 50 % de unos:

$$\chi^2 = \frac{(o - n/2)^2}{n/2} + \frac{((n-o) - n/2)^2}{n/2}. \tag{4}$$

El puntaje de anomalía combina qué tan cerca están p y t de 0.5:

$$s = \frac{\text{máx}(0, 1 - 2|p - 0.5|) + \text{máx}(0, 1 - 2|t - 0.5|)}{2}, \qquad 0 \le s \le 1. \tag{5}$$

El estadístico χ^2 y el puntaje del segundo plano se registran como indicadores complementarios. Un s cercano a 1 significa que la proporción de unos y la frecuencia de transiciones se aproximan al patrón aleatorio esperado por esta heurística; no significa que exista una probabilidad del 100 % de esteganografía.

8.2. Criterios de clasificación y política

La clasificación usa los umbrales configurables $\tau_0 = 0.85$ y $\tau_1 = 0.97$. Para evitar interpretar como sospechoso el ruido que también afecta bits de mayor peso, se compara el puntaje LSB con el segundo plano y se aplica el límite de chi-cuadrado. Sea s_2 el puntaje calculado de igual forma sobre el segundo bit de cada canal:

$$C(s, s_2, \chi^2, n) = \begin{cases} \texttt{no_concluyente}, & n < 1024, \\ \texttt{sospechoso}, & s \ge \tau_1,\ s_2 < \tau_1,\ \chi^2 \le 6.635, \\ \texttt{no_concluyente}, & \tau_0 \le s < \tau_1, \\ \texttt{no_concluyente}, & s \ge \tau_1 \text{ y falla algún criterio complementario}, \\ \texttt{sin_indicios}, & s < \tau_0. \end{cases} \tag{6}$$

Una imagen con menos de 1024 muestras analizadas se considera insuficiente para esta decisión. La clase `sospechoso` requiere simultáneamente el score LSB alto, un score del segundo plano menor al umbral y $\chi^2 \le 6.635$; si no se cumplen conjuntamente, el resultado queda como `no_concluyente`. La política asociada registra cuarentena para sospechosos y advertencia para las demás clases, sin sustituir una revisión especializada.

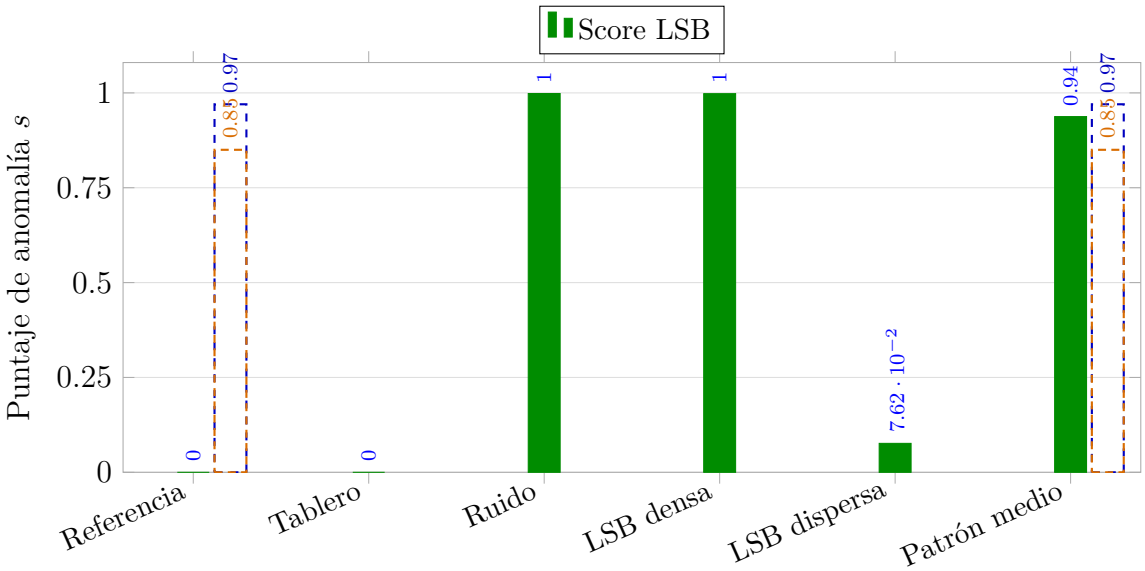


Figura 3: Puntajes documentados de las muestras y umbrales de la heurística. Superar 0.97 no basta por sí solo para clasificar como sospechoso: también se evalúan el segundo plano y χ^2.

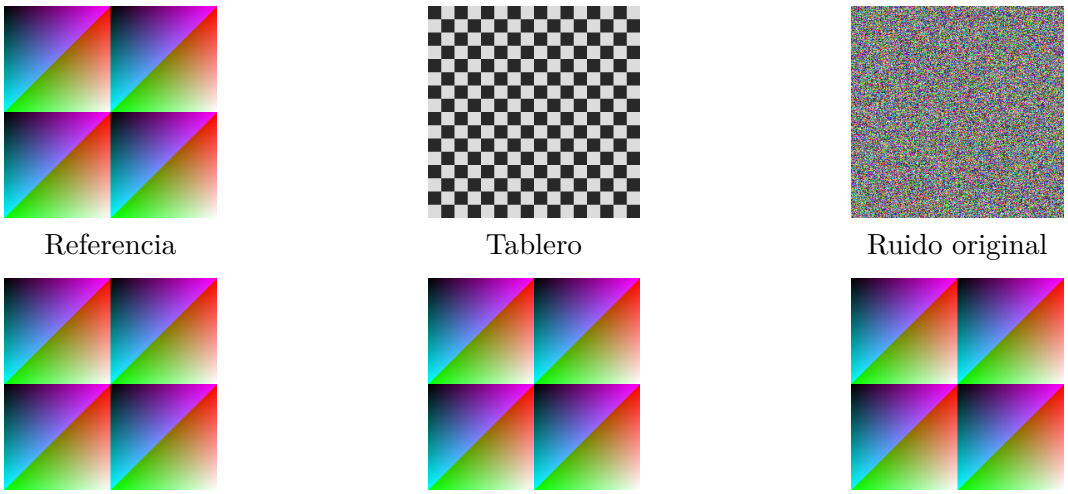


Figura 4: Corpus de imágenes del repositorio. Cada PNG del paquete conserva su contenido original.

Cuadro 5: Muestras y clasificación documentada

Muestra	Resultado	Interpretación
Referencia	Score 0, sin indicios	Negativo esperado
Tablero	Score 0	Patrón determinista
Ruido	0.998324, no concluyente	Ruido compatible con un patrón ambiguo
Carga LSB aleatoria	Score 0.997958, $r = 0.500966$, $q = 0.498924$	Positivo esperado
Carga dispersa	0.076248, sin indicios	Falso negativo posible
Patrón medio	0.937497, no concluyente	Incertidumbre

La carga LSB se verificó bit a bit al generarse. La figura 3 presenta los puntajes reportados; en particular, el ruido alcanza un valor alto y queda no concluyente al aplicar los criterios complementarios. Esto evidencia que el score aislado no es una probabilidad ni una decisión final.

9. Diseño de pruebas y resultados

Cuadro 6: Escenarios de integración y resultados observados

ID	Escenario	Resultado
T01	Inicio/parada independiente	APIs autónomas
T02	Login válido/incorrecto	JWT/401
T03	Token ausente, alterado o vencido	401
T04	USER analiza	403
T05	Asignaciones N:M	Persistidas
T06	Duplicado	409 sin duplicar
T07	Revocar rol y usar JWT vigente	403
T08	AUTH inaccesible	503 sin procesar
T09	PNG original y carga LSB	Métricas y clase
T10	Archivo grande/corrupto/formato inválido	413/422/415
T11	Resultado ajeno	403
T12	Revisión de auditoría	request ID sin secretos

La ejecución local del 5 de noviembre de 2026 aprobó los 12 escenarios de la tabla. Los registros de entrega confirman además que GET y PATCH de roles funcionaron, la credencial fija anterior devolvió 401 y el mismo registro persistió tras recrear STEGO. El plan vigente se encuentra en `Codigo/PLAN_PRUEBAS_PRE_COMMIT.md`.

9.1. Controles previos al commit y Postman

El plan versionado en `Codigo/PLAN_PRUEBAS_PRE_COMMIT.md` distingue tres tipos de verificación.

G01–G08. Control automático

El control previo al commit comprueba los archivos preparados en Git, la validez de la colección QA, el análisis estático y la compilación de ambos servicios. Comprende 36 pruebas unitarias y 17 de extremo a extremo. AUTH utiliza una instancia temporal de PostgreSQL. Las pruebas de STEGO utilizan SQLite y simulan las respuestas de AUTH.

G09. Integración con servicios reales

Se ejecuta por separado cuando cambian los servicios, la configuración de despliegue, las claves o las políticas. Desde `Codigo`, iniciar el entorno de demostración y ejecutar `scripts/test-all.ps1`. El conjunto cubre T01–T12 e incluye la caída de AUTH y la revocación de permisos.

Una prueba aprueba si el resultado observado coincide con el esperado. Por ejemplo, el caso SEC-03 aprueba con HTTP 403 porque un usuario con rol USER intenta analizar una imagen. La evidencia debe identificar el caso, el commit, el resultado esperado, el resultado observado y el identificador de solicitud cuando esté disponible.

9.2. Diseño y uso de la colección de Postman

La colección QA utiliza un entorno independiente para las URL de AUTH y STEGO. Los archivos de importación se encuentran en `Codigo/pruebas/postman-export/`. El entorno de distribución deja vacíos los campos de contraseña y token. Las solicitudes HTTPS requieren la CA de desarrollo. Los archivos PNG se referencian mediante rutas relativas al directorio de trabajo de Postman.

Cuadro 7: Distribución de solicitudes de la colección REST

Grupo	Solicitudes	Comprobación principal
Preparación y sesiones	9	Disponibilidad, login, perfil y obtención de identificadores
Validación y contratos	7	UUID, fecha, datos nulos, campos extra, conflictos y OpenAPI
Autenticación y permisos	5	JWT ausente o alterado, restricción USER e identidad de servicio
Imágenes y resultados	9	Clasificación de muestras, límites y consulta de registros
Revocación y restauración	4	Denegación con el mismo JWT y recuperación del permiso
Cierre de sesión	2	Logout y rechazo del JWT reutilizado
Disponibilidad	1	Respuesta 503 con AUTH detenido

Las solicitudes de inicio de sesión guardan el JWT en una variable del entorno. Las operaciones protegidas lo envían en la cabecera `Authorization` y las cargas usan el campo `file` de `multipart/form-data`. Los guiones de prueba comparan la respuesta real con el código previsto y comprueban campos como el SHA-256 y el estado del análisis. El caso de revocación conserva exactamente el mismo JWT entre el análisis anterior y el posterior al retiro del rol.

En Postman Desktop, el caso OAS-02 obtiene HTTP 200 de `/docs-json` y verifica la presencia del esquema de respuesta de análisis. El caso SEC-01 obtiene HTTP 401 ante una solicitud sin JWT, conforme al requisito de autenticación. El Apéndice D presenta ambas respuestas.

Los resultados de Newman comprenden 36 solicitudes y 54 aserciones aprobadas en los seis grupos principales. El caso DIS-01 verifica la respuesta HTTP 503 cuando AUTH está indisponible. El total asciende a 37 solicitudes y 55 aserciones aprobadas.

10. Riesgos y prácticas seguras

Cuadro 8: Resumen de riesgos

Activo	Amenaza	Control	Residual
Credenciales	Fuerza bruta	Argon2id, límite de intentos	Medio
JWT/clave	Alteración/fuga	RS256, claims, privada sólo AUTH; T03	Bajo/medio
Roles	Elevación	FK/UNIQUE, consulta actual; T05–07	Bajo
Canal	MITM	TLS, CA, credencial aleatoria; T08	Medio; no mTLS
Archivos	Bomba/parser hostil	Firma, MIME, píxeles; T10	Bajo/medio
Resultados	IDOR	Propiedad/ADMIN; T11	Bajo
Logs/datos	Fuga/pérdida	Redacción y volúmenes; T12	Backup inmutable pendiente
Detector	Falsos resultados	Métricas y límites	Alto
Dependencias	CVE	Lockfiles y revisión de alertas	Medio

Zero Trust significa verificar sujeto y permiso por acción; Secure by Design se materializa en separación, mínimo privilegio y denegación por defecto; Shift Left en pruebas adversas tempranas. La relación con ISO es referencial, no certificación ni mapeo normativo.

11. Limitaciones y conclusiones

11.1. Limitaciones

El corpus de demostración ilustra el comportamiento del detector sobre PNG de las características admitidas. Su alcance incluye falsos positivos y falsos negativos. El servicio STEGO se publica por HTTP en loopback durante la demostración. Un despliegue externo requiere terminación HTTPS y controles de red. El secreto de servicio se conserva entre reinicios y su rotación se realiza por instalación. SQLite opera con un único nodo. La recuperación tras pérdida del volumen y la capacidad bajo concurrencia sostenida quedan fuera de las pruebas registradas.

11.2. Conclusiones

El Backend V1 integró identidad persistente, autorización vigente y detección LSB en dos servicios independientes. La migración conservó usuarios, roles y asignaciones mientras normalizó los nombres físicos del esquema. Las pruebas confirmaron el retiro de permisos con un JWT vigente, el fallo seguro durante la caída de AUTH y la recuperación de registros tras recrear STEGO. El equipo aprobó 53 pruebas automáticas, los 12 escenarios oficiales y las 37 solicitudes de la colección ejecutadas con Newman.

12. Instalación, ejecución y sustentación

Requisitos locales: Docker Desktop con Docker Compose, PowerShell, Git con OpenSSL o una instalación equivalente, y Node.js 24 para el control automático de las fuentes. Desde la raíz del proyecto:

```
Set-Location .\Codigo
.\scripts\start-demo.ps1
docker compose ps
```

La preparación genera los secretos de desarrollo, construye los contenedores, aplica las migraciones y prepara las cuentas de demostración. AUTH Swagger está en https://localhost:3001/docs y STEGO Swagger en http://localhost:3002/docs. Configure la CA local en el cliente para validar el certificado de AUTH.

1. Muestre los contenedores, el estado de ambos servicios y sus contratos OpenAPI.
2. Inicie sesión como ANALYST, cargue el PNG de prueba con carga densa y recupere el análisis mediante su UUID.
3. Muestre una asignación N:M y el rechazo de una asignación duplicada. Revoque el rol, repita el análisis con el mismo JWT y restaure el rol.
4. Detenga AUTH y demuestre HTTP 503 en STEGO. Restaure AUTH y compruebe su disponibilidad.

5. Muestre la correlación de una solicitud en los logs y consulte las evidencias de persistencia y de la colección REST.

Para repetir las suites, ejecute desde `Codigo`:

```
npm ci --prefix auth
npm ci --prefix stego
node scripts/check-before-commit.mjs --working-tree
.\scripts\test-all.ps1
.\scripts\test-delivery.ps1
```

La última prueba modifica temporalmente la descripción de un rol, restaura el valor y recrea STEGO conservando su volumen. Ejecute la colección REST por separado. Sus grupos numerados requieren los dos servicios activos. Para DIS-01, detenga AUTH con un JWT ADMIN vigente y restaure el servicio al concluir.

13. Referencias

[1] ISO/IEC (2022), ISO/IEC 27001:2022. https://www.iso.org/standard/27001

[2] ISO/IEC (2011), ISO/IEC 27034-1. https://www.iso.org/standard/44378.html

[3] OWASP (2025), ASVS 5.0. https://asvs.owasp.org/

[4] OWASP, File Upload Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

[5] Jones et al. (2015), JWT, RFC 7519. https://www.rfc-editor.org/rfc/rfc7519

[6] Jones (2015), JWK, RFC 7517. https://www.rfc-editor.org/rfc/rfc7517

[7] Sheffer et al. (2020), JWT Best Current Practices, RFC 8725. https://www.rfc-editor.org/rfc/rfc8725

[8] Rose et al. (2020), NIST SP 800-207. https://doi.org/10.6028/NIST.SP.800-207

[9] DCCO (2026), *Proyecto Integrador del Primer Parcial*. Universidad de las Fuerzas Armadas ESPE.

A. Matriz completa de activos, amenazas y controles

La matriz siguiente cubre activos, amenazas, vulnerabilidades o causas, impacto, probabilidad, riesgo inherente, controles, evidencia y riesgo residual. La valoración es cualitativa y se apoya en los escenarios y controles descritos en el informe.

Cuadro 9: Matriz integral de riesgos de seguridad

Dimensión	Activo	Amenaza	Causa	Impacto	Prob.	Inicial	Control aplicado	Evidencia	Residual
Autenticación	Credenciales	Fuerza bruta	Reutilización y ataques distribuidos	Alto	Media	Alto	Argon2id, error genérico y límite de intentos	AuthService, T02	Medio
Confidencialidad	Hash de clave	Fuga de BD	Ataque offline al hash	Alto	Baja	Medio	Argon2id con sal; campo excluido de consultas	User entity/service	Medio
Integridad	JWT	Alteración de claims	Payload legible y manipulable	Alto	Alta	Alto	RS256, algoritmo fijo, iss/aud/exp/typ	T03, variantes 401	Bajo
Confidencialidad	Clave privada RSA	Exfiltración	Secreto montado en AUTH	Crítico	Baja	Alto	Privada sólo en AUTH; STEGO sólo recibe pública	Compose y mounts	Medio
Autenticación	Sesión	Robo de token	Bearer utilizable hasta expiración	Alto	Media	Alto	Expiración 15 min, logout y tokenVersion	T03 y logout	Medio
Autorización	Roles	Permiso obsoleto	Confiar en roles incluidos en JWT	Alto	Media	Alto	Roles no van en JWT; consulta vigente en BD	activeRoles, T07	Bajo
Autorización	Asignación N:M	Duplicación/ inconsistencia	Concurrencia o falta de unicidad	Medio	Baja	Bajo	FK y UNIQUE(user_id,role_id)	BD, T05–T06	Bajo
Autorización	API administrativa	Omisión de guard	Evolución de controladores	Alto	Baja	Medio	JwtAuthGuard, RolesGuard y rol ADMIN	Controladores AUTH	Bajo/medio
Autorización	Resultados	IDOR/acceso horizontal	UUID ajeno conocido	Alto	Media	Alto	Propietario o ADMIN con rol vigente	StegoService.get, T11	Bajo
Integridad	Decisión AUTH	Suplantación de STEGO	Suplantación si se obtiene el secreto	Alto	Baja	Medio	HTTPS, CA, secreto aleatorio y request ID	Endpoint interno, T08	Medio; sin mTLS/rotación
Confidencialidad	Canal AUTH–STEGO	MITM	CA/certificado mal administrado	Alto	Baja	Medio	TLS validado y sin flags de omisión	Configuración Compose	Bajo
Confidencialidad	API STEGO	Escucha en red	HTTP si se publica fuera de loopback	Alto	Baja	Medio	Binding loopback; HTTPS requerido al exponer	Compose	Bajo local; alto si se expone
Disponibilidad	AUTH	Caída/timeout	Dependencia central de autorización	Alto	Media	Alto	Timeout, healthcheck y fail-closed 503	authorize, T08	Medio

Dimensión	Activo	Amenaza	Causa	Impacto	Prob.	Inicial	Control aplicado	Evidencia	Residual
Disponibilidad	Memoria STEGO	Archivo enorme	Multipart en memoria	Alto	Media	Alto	Máximo 5 MiB, un archivo y autorización previa	Controller, T10=413	Bajo
Disponibilidad	CPU/memoria	Bomba de descompresión	Archivo pequeño con muchos píxeles	Alto	Media	Alto	Límite 16 Mpx y decodificación estricta	Sharp, T10=422	Bajo/medio
Integridad	Parser de imagen	Formato disfrazado	Confiar sólo en MIME/extensión	Alto	Media	Alto	Firma real, MIME, extensión, PNG y failOn estricto	T10=415/422	Bajo
Disponibilidad	Dependencias	Vulnerabilidad de tercero	Paquetes externos	Alto	Media	Alto	Lockfiles y actualización controlada	npm audit/build	Medio, sujeto a la versión desplegada
Integridad	Registro de análisis	Sustitución de evidencia	Archivo fuente no retenido	Medio	Baja	Bajo	SHA-256 y fecha en registro	Tabla analyses	Bajo/medio
Trazabilidad	Logs	Falta de correlación	Servicios concurrentes	Medio	Media	Medio	Request ID generado y propagado	Middleware, T12	Bajo
Confidencialidad	Logs	Exposición de secretos	Registrar cuerpos/cabeceras completos	Alto	Media	Alto	Lista de campos permitidos; omitir tokens/claves/passwords	AuditService, T12	Bajo
Trazabilidad	Auditoría	Manipulación/ borrado	stdout de runtime sin centralización	Alto	Baja	Medio	JSON correlacionado consultable	docker compose logs	Medio
Disponibilidad e integridad	PostgreSQL	Pérdida/ corrupción	Borrado o falta de backup probado	Crítico	Baja	Alto	Volumen persistente; evitar down -v	Compose, reinicio	Medio
Integridad	Esquema AUTH	Despliegue incompatible	Omitir migración de cambio	Alto	Media	Alto	synchronize=false y migraciones versionadas	Migración inicial	Medio
Disponibilidad	SQLite	Bloqueo/ concurrencia	Persistencia mononodo	Medio	Baja	Bajo	WAL y volumen; carga académica baja	StegoService	Bajo local; medio al escalar
Precisión	Imágenes normales	Falso positivo	Ruido natural con LSB aleatorio	Medio	Media	Medio	Indicio y advertencia de limitación	Muestra ruido	Medio
Precisión	Carga oculta	Falso negativo	Señal dispersa o débil	Alto	Media	Alto	Explicar límite y no afirmar certeza	Muestra dispersa	Alto
Precisión	Detector	Evasión	Técnicas no LSB/adaptativas	Alto	Media	Alto	Alcance restringido y limitaciones persistidas	Campo limitations	Alto
Precisión	Clasificación	Sobreajuste	Ajuste a muestras conocidas	Alto	Baja	Medio	No forzar umbrales; requerir corpus independiente	Resultados experimentales	Medio

Dimensión	Activo	Amenaza	Causa	Impacto	Prob.	Inicial	Control aplicado	Evidencia	Residual
Integridad y autorización	Acción de análisis	Confundir score con permiso	Mezclar precisión con autorización	Alto	Baja	Medio	RBAC se verifica antes del detector	Flujo Controller/Service	Bajo

B. Matriz de enfoque y principios

Cuadro 10: Relación entre controles y enfoques de seguridad

Control	Zero Trust	Secure by Design	Shift Left	Relación con ISO/IEC 27001 y 27034
Verificar JWT y permiso actual ante cada solicitud	Verificar explícitamente	Denegación por defecto y mínimo privilegio	T03, T07 y T08	Gestión de acceso y seguridad de aplicaciones
Separar AUTH, STEGO, claves y BD	Limitar confianza	Separación y reducción de privilegios	Revisar Compose en integración	Diseño y operación segura
Validar firma, MIME, tamaño y píxeles	Entrada no confiable	Validación por capas y límites	Pruebas adversas T10	Requisitos de seguridad y riesgo
Proteger secretos y depurar auditoría	Identidad de servicio comprobada	Minimizar exposición	Revisar logs y pruebas	Protección de información y trazabilidad

Esta relación es académica, no correspondencia de cláusulas ni certificación.

C. Matriz de evidencia reproducible

Cuadro 11: Evidencia asociada a requisitos y sustentación

ID	Evidencia a presentar	Ubicación/forma de reproducción	Resultado documentado
T01	Arranque y parada autónomos	`scripts/test-independence.ps1`; Compose	Servicios independientes
T02	Login correcto e incorrecto	`scripts/test-core-security.ps1`	JWT RS256 / 401
T03	JWT ausente, alterado y expirado	`scripts/test-jwt-special.ps1`	401
T04	USER intenta analizar	`scripts/test-core-security.ps1`	403
T05	Usuario con dos roles y rol compartido	setup-demo y verificación SQL	Cuatro asociaciones N:M
T06	Asociación repetida	`scripts/test-core-security.ps1` y consulta BD	409, una fila
T07	Retirar rol y repetir con mismo JWT	`scripts/test-core-security.ps1`	403
T08	AUTH fuera de servicio	`scripts/test-fail-closed.ps1`	503 sin análisis

ID	Evidencia a presentar	Ubicación/forma de reproducción	Resultado documentado
T09	PNG de referencia y muestra LSB	`samples/`, `scripts/test-detector.ps1`	Score 0 y 0.997958 documentados
T10	Grande, truncado, 25 Mpx, GIF y JPEG disfrazado	`scripts/test-t10.ps1`	413, 422 y 415. Registro de error en los dos 422
T11	Acceso a análisis de otro usuario	`scripts/test-core-security.ps1`	403
T12	Eventos y request ID sin secretos	Logs Compose; request ID `t12-analysis`	Eventos correlacionados
OpenAPI	Contratos AUTH y STEGO	https://localhost:3001/docs; http://localhost:3002/docs	Swagger en ejecución
Persistencia	Recreación de STEGO	`scripts/test-delivery.ps1`	Mismo UUID, SHA-256 y clasificación
Claves/TLS	Separación de clave privada y CA	Compose, mounts y búsqueda de opciones inseguras	Privada sólo AUTH; verificación activa

D. Evidencias de ejecución

La evidencia comprende la disponibilidad de los servicios, el cumplimiento de los contratos REST, los controles de acceso y la persistencia de los análisis.

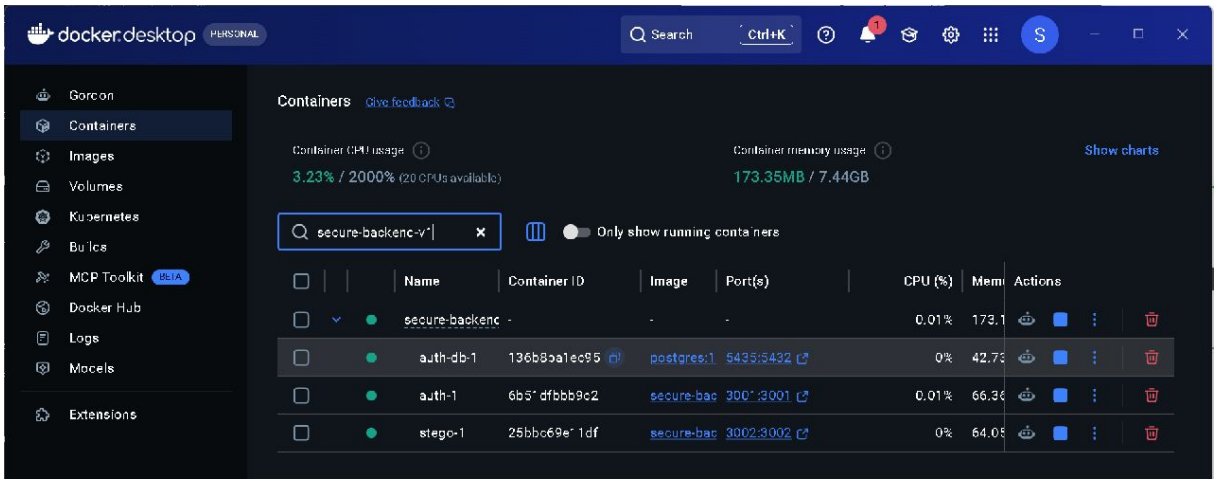


Figura 5: Docker Desktop muestra AUTH, STEGO y PostgreSQL activos en el proyecto local.

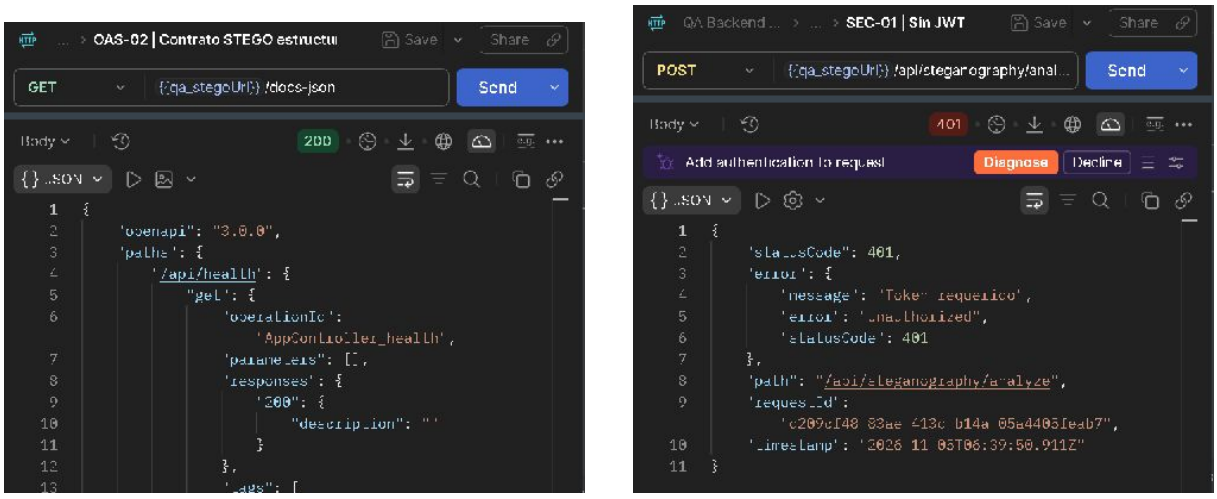


Figura 6: Solicitudes ejecutadas en Postman Desktop. Izquierda: el caso OAS-02 recupera el contrato OpenAPI con HTTP 200. Derecha: SEC-01 recibe HTTP 401 al intentar analizar sin JWT.

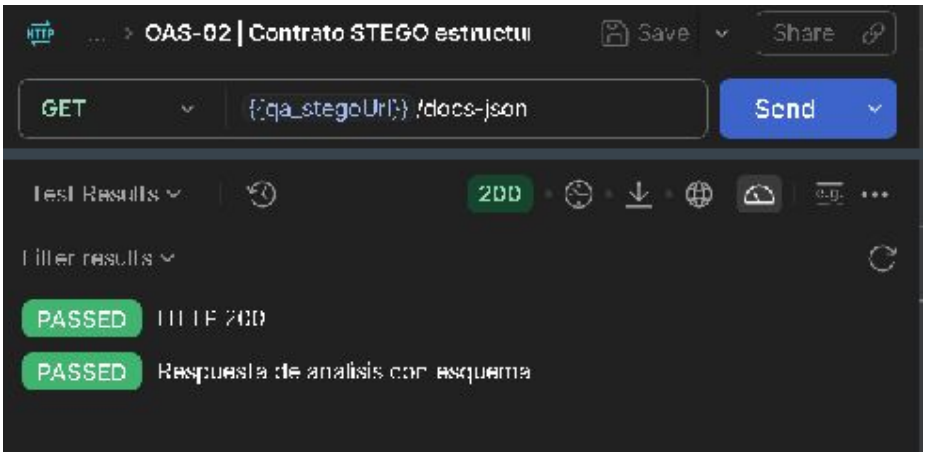


Figura 7: Panel Test Results de Postman Desktop para OAS-02. Las dos aserciones comprueban el código 200 y la presencia del esquema de respuesta de análisis.

Control automático del área de trabajo

5 de noviembre de 2026 | Evidencia de ejecución local

```
[PRE-COMMIT] auth: lint, build y unitarias
Tests:       14 passed, 14 total
[PRE-COMMIT] stego: lint, build y unitarias
Tests  22 passed (22)
[PRE-COMMIT] npm run test:e2e --prefix auth -- --runInBand
Tests:       11 passed, 11 total
[PRE-COMMIT] npm run test:e2e --prefix stego
Tests  6 passed (6)
PASS: comprobaciones previas al commit aprobadas.
```

Figura 8: Control local con 36 pruebas unitarias y 17 de extremo a extremo aprobadas.

Integración con AUTH y STEGO en Docker

5 de noviembre de 2026 | Evidencia de ejecución local

```
PASS T04 USER denied (403)
PASS T07 before revocation (201)
PASS T07 after revocation, same JWT (403)
PASS T11 foreign resource (403)
PASS T12 trazabilidad administrativa y ausencia de secretos
PASS T08 AUTH unavailable (503)
PASS T08 AUTH restored (200)
PASS T01 AUTH with STEGO stopped (200)
PASS T01 STEGO with AUTH stopped (200)
PASS integration suite
```

Figura 9: Resultados de integración entre AUTH y STEGO.

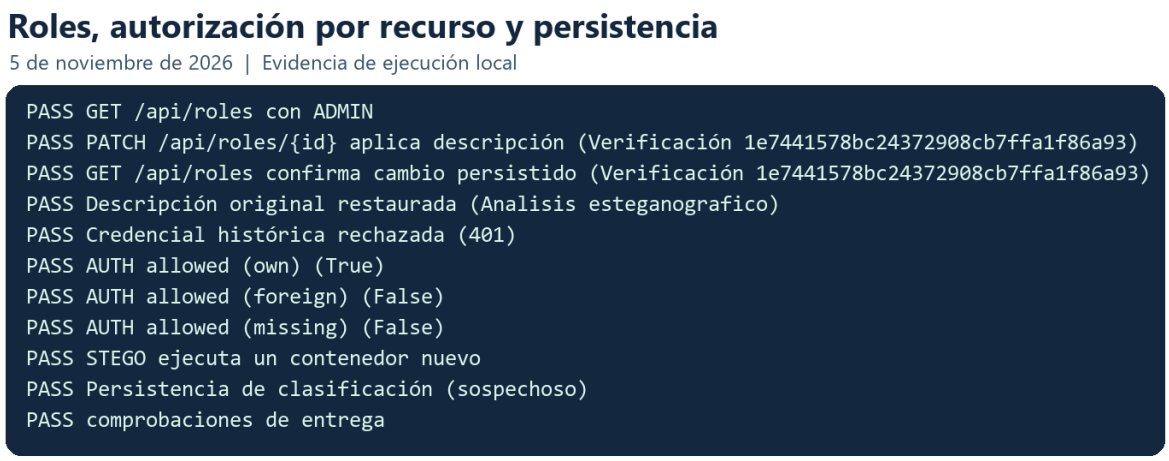


Figura 10: Actualización de roles, autenticación entre servicios, decisión por recurso y persistencia tras recrear STEGO.

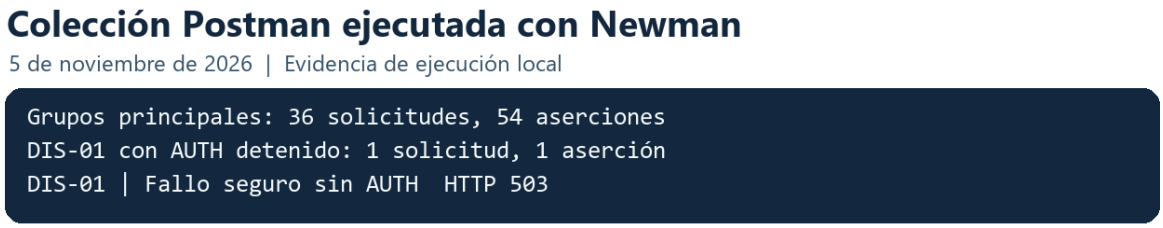


Figura 11: Resultados de la colección Postman en Newman. DIS-01 verifica HTTP 503 cuando AUTH está indisponible.

D.1. Backend en ejecución en Swagger

Las Figuras 12 y 13 muestran las interfaces de exploración de las dos API locales. AUTH expone las operaciones de identidad y administración. STEGO expone el análisis de imágenes y la consulta de resultados.

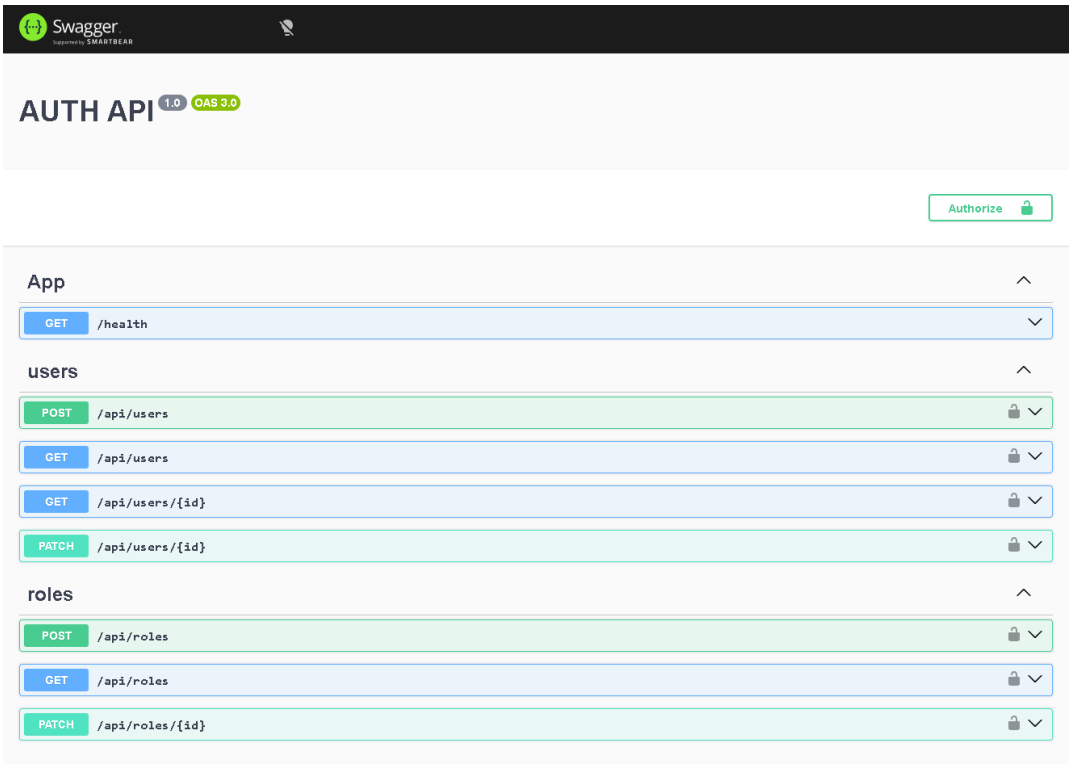


Figura 12: Swagger de AUTH con las rutas de estado, usuarios y roles.

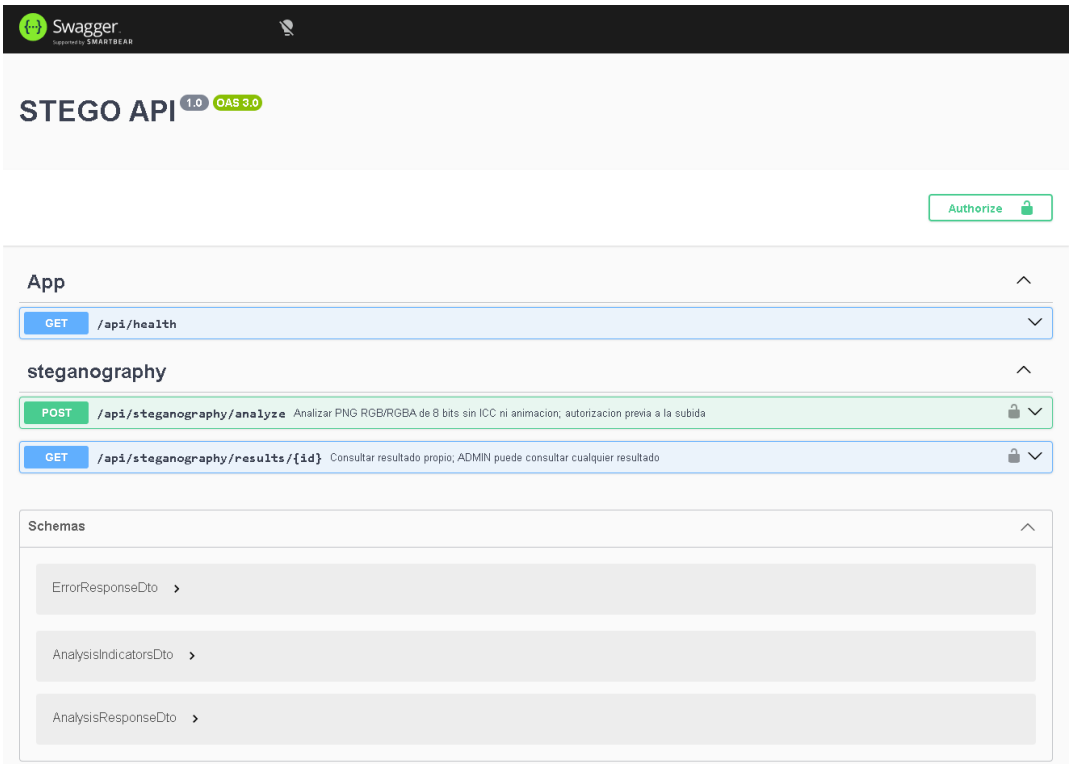


Figura 13: Swagger de STEGO con las operaciones de análisis y consulta.

D.2. Creación y consulta de un análisis

El análisis de la muestra PNG con carga LSB devuelve HTTP 201 y la clasificación `sospechoso` para una sesión con rol ANALYST. La consulta por UUID devuelve HTTP 200 con el mismo identificador y la misma huella SHA-256, lo que confirma la recuperación del registro original.

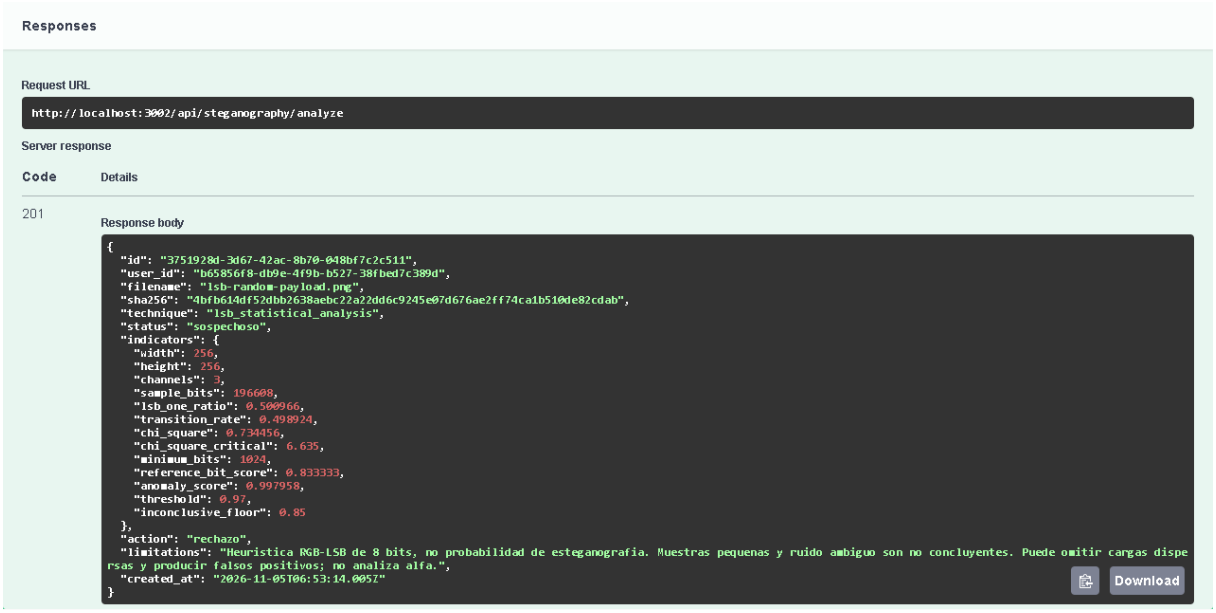


Figura 14: HTTP 201 al crear el análisis. El cuerpo muestra la clasificación, las métricas LSB y la huella SHA-256.

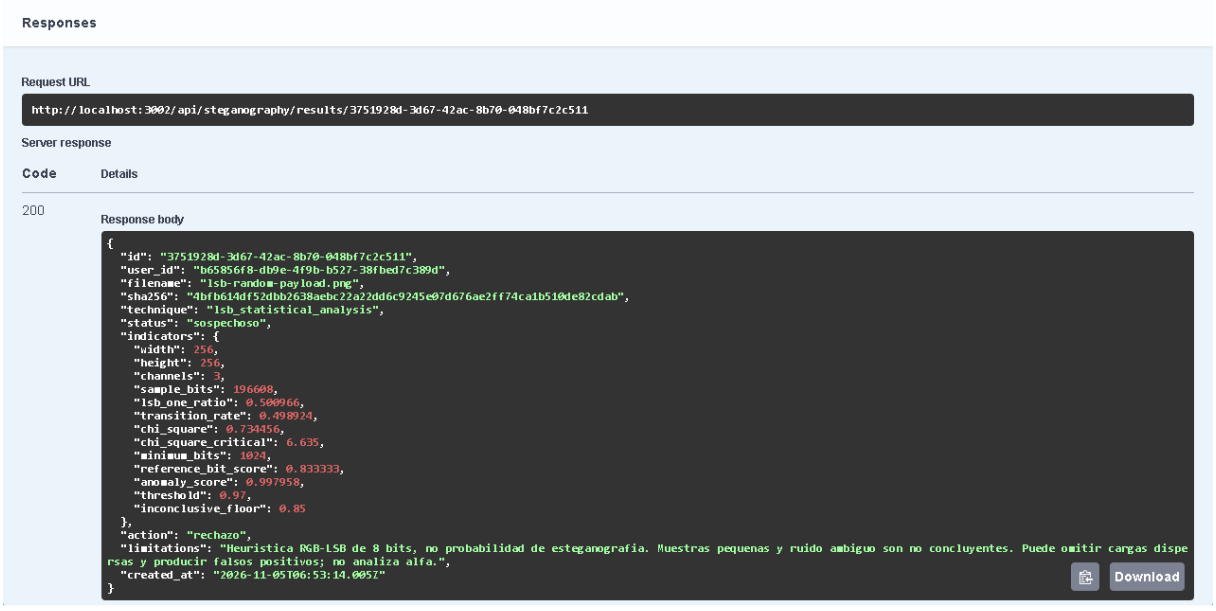


Figura 15: HTTP 200 al consultar el mismo análisis por UUID.

E. Repositorio y artefactos técnicos

Repositorio del proyecto (código, configuración, colección REST, muestras y scripts): https://github.com/Dval05/DES-SW-SEGURO-36902-DDE/tree/main/Unidad%201/Proyecto

Cuadro 12: Artefactos técnicos y ubicación

Entregable del proyecto	Archivo o ruta del repositorio
Dos backends separados	`Codigo/auth/` y `Codigo/stego/`
README, configuración de ejemplo y Docker Compose	`Codigo/README.md`, `auth/.env.example`, `stego/.env.example`, `Codigo/docker-compose.yml`
Migraciones de AUTH	`Codigo/auth/src/migrations/`. Esquema inicial y migración de nombres del Anexo C
Diagrama de arquitectura y entidad-relación	Figuras 1 y 2 de este informe
JWT, RBAC y matriz de permisos	Sección 7
OpenAPI	Swagger generado en ejecución en ambos servicios
Justificación y limitaciones de esteganografía	Sección 8
Matriz de riesgos	Tabla 9
Pruebas y auditoría	Tablas 11 y 6, además de `Codigo/PLAN_PRUEBAS_PRE_COMMIT.md`
Colección REST y entorno	Exportación QA en `Codigo/pruebas/postman-export/` y versión YAML en `Codigo/pruebas/postman/`
Muestras originales y modificadas	`Codigo/samples/original/` y `Codigo/samples/stego/`

La colección versionada facilita repetir solicitudes. Cada corrida debe acompañarse del resultado observado, la fecha y el commit evaluado. El README describe el arranque del entorno y el plan pre-commit detalla el orden de verificación.